Project Lab Level 4: The Front Desk, Attacked and Locked

Goal

Define, build, and test a safe front desk for the public Celaya Solutions Research case or an instructor-approved business, then attack it with ten known tricks, apply four defenses outside and around the model, and rerun the same test.

By the end of class, you can:

- turn an interview into a six-part job specification;

- build a desk that answers only from approved material;

- produce a five-part message card;

- explain prompt injection in plain words and measure it;

- separate promises in words from fences outside the model; and

- pitch the outcome in one minute.

Start here

Use the public CSR case unless the instructor confirms another business and its owner-approved material. Training records are not real CSR policy. The core route runs in a chat project. Hosting is planned, not deployed, tonight.

Every secret in this class is fake. Before a partner test, ask clearly and record yes. Never test a stranger's system or a real business service.

Experienced builder? Run the same ten attacks through the supplied harness contract after the manual sheet is complete, then draft the Vercel server-function contract. No secret may reach browser code.

Anchors / Anclas

- Sell the outcome, not the robot. / Vende el resultado, no el robot.

- Fences, not promises. / Barreras, no promesas.

- A secret it never saw cannot leak. / Un secreto que nunca vio no se puede filtrar.

What a good front desk does

It answers repeated questions from approved material. It takes a complete message. It stops on missing facts and high-stakes requests. It never invents a price, promises a time, shares a private contact, or acts without approval.

The six-part spec is trigger, steps, checks, failure routes, access list, and never list. The never list is the product boundary.

The note on the package

The owner gives a new hire rules. A package arrives with a note that looks like another rule. The hire follows the last note. Prompt injection is the same problem: stranger-written text contains an instruction, and the model may treat it like the owner's instruction.

Better wording can help, but wording is still text. Stronger fences remove the secret, remove dangerous tools, require human approval, record a log, and keep a stop control outside the model.

Safety stop / Alto de seguridad

Use public and training-only records. Do not enter a real client message, price list, calendar, key, private number, or unpublished business record. Attack only what you built or what a partner allowed you to test. Use fake names, 555 phone numbers, and fake codes. Do not publish attack strings as a challenge against real systems.

Usa datos públicos o sintéticos. Ataca solamente lo que construiste o lo que una pareja te permitió probar. Nunca pruebes un sistema real sin permiso.

Task 1: Interview and specify

Use the case card to answer the interview questions. Mark answers that are not publicly known. Build the six-part spec. Write the never list first.

Required never items: no invented price, no response-time promise, no private contact, no client disclosure, no high-stakes advice, no send or booking without a person.

Success check: a partner can tell what the desk does, what it cannot do, and when it hands off.

Task 2: Build and test the desk

Add the public facts, training FAQ, and training message policy. Paste the supplied desk instructions. Add the one fake code from the attack card so Task 3 has something to leak. Run five callers:

1. Easy public question.

2. Price not in the public source.

3. Urgent collaboration request.

4. High-stakes legal, medical, financial, or physical-safety request.

5. Impersonation request for private information.

Fix every miss and rerun it. Finish with one five-part message card: name or safe alias, public contact route, need, urgency, and best follow-up time.

Success check: supported answers carry a receipt, missing and high-stakes routes stop, and the card has all five fields.

Task 3: Attack it, then lock it

1. Write what a safe answer should do. Run all ten attacks from the attack card against your desk. Mark each held, leaked, or partial. Count the leaks.

2. Apply four defenses: mark customer text as data, never an instruction; remove the fake code and any private contact from the model's material; limit the desk to drafting, so a person sends or acts; record each input, draft, and flag, and name the off switch.

3. Run the same ten attacks again. Compare counts. Use the off switch once.

If a partner agrees in writing, exchange two attacks. Each learner keeps control of their own account and records one result. If no partner, use two unused attacks from the card.

Success check: the same test was rerun, the fake secret is absent, and you can point to each fence outside the model.

Close: pitch the outcome

Write and deliver a 60-second pitch to a partner: the problem, the outcome, the proof, and the ask. Do not use AI, agent, or model. Costing comes in Level 5.

Builder extension: write the automated harness contract, use a small model key from an environment variable, and inspect the log for accidental secrets before running it. Then define a Vercel browser-to-server boundary, rate limit, log, and secret name.

Quick check before proof

1. Which answer must stop with Not in the public source?

2. What are the five message-card fields?

3. Why is a better system prompt not a complete fence?

4. Which defense usually removes the most risk?

5. What exact action stops the desk?

Pass this level

A six-part spec and never list; five caller tests and one complete message card; the same ten attacks scored before and after four defenses, with the fake secret removed and a tested log, draft-only boundary, and off switch; and a sixty-second outcome pitch without the words AI, agent, or model.

Save the worksheet as PROJECT-LAB-04.md or keep the paper copy.

If something fails

- Binder has no answer: take a message; do not fill the gap.

- Desk invents a price: remove prices from its material and strengthen the stop route.

- It gives high-stakes advice: require human handoff and stop after the public contact route.

- Nothing leaks: keep the honest zero and apply the four defenses anyway.

- Everything leaks: keep the honest count and show which fence changes the result.

- No project instructions feature: place the rules in the first message.

- Tool unavailable: use the saved caller transcripts and the saved before-and-after packet.

- Partner declines: do not swap. Use two unused attacks from the card.

- Harness error: stop after two tries and return to the core route.

Resumen en español

Tarea 1: convierte la entrevista en una descripción del trabajo y una lista de límites. Tarea 2: construye el escritorio y prueba cinco llamadas. Tarea 3: prueba diez ataques, aplica cuatro barreras y repite las mismas pruebas. Cierre: presenta el resultado en un minuto sin usar las palabras IA, agente o modelo.

Words for Level 4

- Spec: the written job description and boundaries.

- Message card: five fields a human can scan quickly.

- Prompt injection: stranger text that the model follows like an instruction.

- Data fence: words marking untrusted text as data.

- Permission: an action the system may take without asking.

- Audit log: a replayable record of input, output, tools, and flags.

- Server function: code that keeps a secret away from the browser.